

DataSafe Room — Dataspace de colaboración controlada industrial

Documento interno para Ventura / Black Tower Consulting. No enviar a cliente como promesa cerrada sin adaptar a sector, datos disponibles, alcance, legal/security review y QA final.

0. Veredicto ejecutivo

DataSafe Room no debe venderse como “un dataspace Gaia-X”. Debe plantearse como una **sala controlada de colaboración de datos industriales** para resolver un caso concreto entre empresas sin entregar datos brutos por defecto, con mínima exposición, permisos por rol, reglas de salida, aprobaciones, evidencias y trazabilidad.

La oportunidad inicial más defendible es:

- **Wedge 1 — PCF / sostenibilidad de producto cliente-proveedor:** recopilar, revisar y compartir evidencias de huella de producto, Scope 3 o sostenibilidad sin revelar receta, costes, capacidad ni proceso completo.
- **Wedge 2 — Data Act readiness para maquinaria conectada:** inventariar datasets de producto conectado, derechos de acceso, restricciones, secretos comerciales y flujos de entrega controlada.
- **Wedge 3 — Calidad/trazabilidad multiempresa:** investigar incidencias, recalls, no conformidades o auditorías compartiendo solo la evidencia mínima.

Decisión de producto: construir primero una demo/diagnóstico y luego un MVP operativo acotado. No construir un dataspace federado completo al inicio.

1. Lenguaje comercial seguro

1.1 Mensaje central

DataSafe Room es una sala controlada para colaborar con datos industriales en un caso concreto, empezando con datos exportados o sintéticos, permisos por rol, reglas de salida, aprobación y evidencias. No sustituye revisión legal, no certifica cumplimiento ni requiere abrir sistemas productivos en el primer piloto.

1.2 Tagline

Comparte valor. Conserva el control.

1.3 No decir

- “Creamos un dataspace Gaia-X/IDSA conforme.”
- “Cumplimiento Data Act/GDPR/NIS2/CSRD garantizado.”
- “PCF certificado.”
- “Seguridad total.”
- “Integramos ERP/MES/SCADA/PLC en 7 días.”
- “Anonimizamos todos los datos sin riesgo.”
- “Sin entregar datos brutos” como absoluto.

1.4 Decir

- “Sala controlada de colaboración por caso.”
- “Datos mínimos, finalidad concreta y reglas de salida.”
- “Audit pack para revisar qué se compartió, quién aprobó y qué salió.”
- “Preparación operativa y evidencias para revisión legal/compliance.”
- “Datos exportados, sintéticos o muestras aprobadas antes de tocar sistemas productivos.”
- “Sin entregar datos brutos por defecto; cualquier salida cruda requiere aprobación explícita y alcance contractual.”

2. Usuarios, organizaciones y roles

2.1 Organizaciones participantes

- **Data Provider:** proveedor/fabricante que aporta datos, evidencias o declaraciones.
- **Data Consumer / Requester:** cliente, OEM, auditor o comprador que solicita información.
- **Room Operator:** Black Tower o equipo interno que configura la sala y facilita el piloto.
- **Auditor / Reviewer:** rol limitado para revisar evidencias o export final.
- **Legal / Security / DPO:** rol de revisión, no necesariamente usuario diario.

2.2 Roles funcionales mínimos

- **Room Owner:** crea sala, define finalidad, invita participantes y cierra el piloto.
- **Data Steward:** valida campos, owners, sensibilidad y calidad del dato.
- **Provider Contributor:** aporta datos/evidencias, responde gaps y solicita protección.
- **Requester Viewer:** ve outputs aprobados y estado de completitud, no datos internos.
- **Approver:** aprueba salida/export de evidencias o resultados.
- **Output Reviewer:** revisa si un informe/export contiene campos no permitidos.
- **Auditor:** consulta logs y evidencias autorizadas.
- **Admin IT/Security:** gestiona identidad, dominios, retención, incidentes y hardening.

2.3 RACI mínimo por sala

- **Sponsor de negocio:** decide si el caso merece piloto.
- **Room Owner:** responsable operativo de la sala.
- **Data Owner por dataset:** autoriza uso, alcance y sensibilidad.
- **Approver de salida:** aprueba qué puede ver cada parte.

- **IT/Security:** valida riesgos si hay datos reales, externos o integración.
- **Legal/DPO:** valida contratos, RGPD, Data Act o secretos si aplica.

3. Casos de uso prioritarios

3.1 PCF / sostenibilidad de producto

Problema: clientes grandes piden datos de carbono, materiales, evidencias ESG o Scope 3. El proveedor teme revelar recetas, consumos, costes o volúmenes.

Resultado esperado: sala donde cada proveedor aporta evidencias y datos mínimos; el cliente ve PCF agregado, estado de completitud, gaps y evidencias aprobadas.

Features clave:

- Plantilla PCF por producto/lote/familia.
- Unidad funcional, periodo, geografía y metodología declarada.
- Factores de emisión y fuente.
- Datos primarios vs estimados.
- Evidencias adjuntas versionadas.
- Scoring de calidad del dato.
- Campos internos excluidos del output.
- Export pack para revisión interna/auditoría, no certificación.

3.2 Data Act readiness para maquinaria conectada

Problema: fabricantes de productos conectados pueden tener que facilitar acceso a datos generados por productos, sin regalar secretos comerciales ni know-how.

Resultado esperado: inventario de datasets, roles legales, restricciones, formatos de entrega y flujo de solicitud/aprobación.

Features clave:

- Registro de producto/activo conectado.
- Clasificación de datasets generados.
- Identificación de data holder, user y third-party recipient.
- Workflow de solicitud de acceso.
- Restricciones de uso y duración.
- Registro de rechazos/suspensiones por secreto comercial o riesgo.
- Export/API machine-readable en fase posterior.

3.3 Calidad y trazabilidad multiempresa

Problema: incidencias, recalls, no conformidades o garantías requieren datos de varios participantes, pero compartir el proceso completo es inviable.

Resultado esperado: investigación controlada con evidencia mínima, trazabilidad de versiones y decisión compartible.

Features clave:

- Caso/incidencia con finalidad y alcance.
- Mapa entrada → transformación → salida, si aplica.
- Evidencias por lote, certificado, inspección o no conformidad.
- Roles de proveedor, cliente y auditor.
- Timeline de eventos.
- Export de informe de investigación con campos aprobados.

4. Principios de arquitectura

1. **Finalidad antes que acceso:** ninguna sala existe sin caso, objetivo, participantes, datos mínimos y reglas de salida.
2. **Controlled Export First:** no abrir PLC/SCADA/MES/ERP al principio. Usar CSV, Excel, PDF, documentos, datos sintéticos o export aprobado.
3. **Deny by default:** usuario invitado no ve nada hasta asignación explícita.
4. **Mínima exposición:** pedir solo campos necesarios; preferir agregados, rangos, ratios o referencias cuando sea suficiente.
5. **Salida gobernada:** no todo lo que entra puede salir; todo output sensible requiere revisión/aprobación.
6. **Trazabilidad verificable:** logs de creación, cambios, accesos relevantes, aprobaciones y exportaciones.
7. **Interoperabilidad progresiva:** modelar conceptos de asset/policy/agreement/catalog desde el MVP, pero dejar EDC/DSP/federación para fases posteriores.
8. **No compliance automático:** el producto estructura evidencias y controles; no sustituye asesoría legal, auditoría ni certificación.

5. Capas del sistema

5.1 Capa de sala / caso

- Crear sala con nombre, finalidad, alcance, fechas, sponsor y owner.
- Definir organizaciones participantes.
- Declarar qué problema resuelve y qué queda fuera.
- Configurar estado: draft, active, review, closed, archived.
- Definir retención y cierre.

5.2 Capa de identidad y acceso

- Multi-organización / multi-tenant desde el diseño.
- Invitaciones con caducidad y dominio permitido.
- RBAC mínimo por rol.
- ABAC por organización, sala, sensibilidad, finalidad, estado de aprobación, caducidad y tipo de export.
- SSO/OIDC/SAML y MFA para v1/enterprise.
- Revocación inmediata de usuarios, links, tokens y accesos futuros.

5.3 Capa de catálogo y data products

- Data Product / Dataset con owner, fuente, versión y sensibilidad.
- Campos con propósito, obligatoriedad, salida permitida y nivel de riesgo.
- Estado de calidad: pendiente, incompleto, aprobado, rechazado, obsoleto.
- Metadatos inspirados en DCAT: título, descripción, publisher, temporalidad, formato, licencia/restricciones, contacto, distribución.
- Tags por PCF, Data Act, calidad, trazabilidad, DPP, secreto comercial, personal data.

5.4 Capa de ingestión controlada

MVP:

- Formularios.
- Upload de CSV/XLSX/PDF/ZIP limitado.
- Datos sintéticos o muestra aprobada.
- Mapeo selectivo de columnas.
- Rechazo de columnas no mapeadas.
- Adjuntos con owner, versión, fecha y sensibilidad.

V1+:

- SFTP/bucket privado.
- Conectores a almacenamiento cloud.
- API scoped tokens.
- Export de ERP/MES/PLM vía proceso aprobado.

Fuera del inicio:

- PLC/SCADA directo.
- Streaming industrial continuo.
- Historian directo sin threat model.
- Agentes dentro de red OT.

5.5 Capa de políticas y contratos

- Data Sharing Agreement por sala.
- Data Use Agreement por finalidad.
- NDA / confidencialidad si hay datos sensibles.
- DPA si hay datos personales.
- Anexo de seguridad si hay externos o datos reales.
- Versionado de términos aceptados.
- Política machine-readable inspirada en ODRL: permisos, prohibiciones, obligaciones y restricciones.
- Condiciones: finalidad, duración, destinatarios, export, retención, no reverse engineering, no benchmark no autorizado, no uso competitivo si aplica.

5.6 Capa de workspace / revisión

- Vistas por rol.

- Checklist de completitud.
- Revisión de evidencias.
- Comentarios y solicitudes de corrección.
- Estado por campo/evidencia.
- Preview: “esto verá proveedor/cliente/auditor”.
- Bloqueo si hay datos sin owner, sin clasificación o sin aprobación.

5.7 Capa de output controls

- Export permitido/prohibido por política.
- Export final con finalidad, alcance, versión, fecha, participantes, autorizaciones, disclaimers y limitaciones.
- Watermarking en v1.
- Hash de export en v1.
- Vistas online revocables.
- Advertencia explícita: archivos ya descargados no pueden “desverse”; se controlan por contrato, watermark y auditoría.

5.8 Capa de auditoría y linaje

Eventos mínimos:

- Sala creada/cerrada.
- Usuario invitado/revocado.
- Dataset creado/modificado/eliminado.
- Evidencia subida/versionada.
- Campo clasificado.
- Política aceptada/cambiada.
- Output solicitado/revisado/aprobado/rechazado/exportado.
- Acceso relevante a vista o evidencia sensible.

Linaje mínimo:

- Fuente → dataset → versión → transformación/revisión → output → export/audit pack.

MVP:

- Audit log funcional no editable desde UI.

V1+:

- Append-only real, hash chain, WORM/Object Lock, SIEM y alertas.

6. Modelo de objetos

6.1 Objetos principales

- **Room:** finalidad, alcance, participantes, fechas, owner, estado, retención.
- **ParticipantOrg:** empresa, rol, dominio, acuerdos, contactos.

- **User:** identidad, organización, rol, permisos, MFA, estado.
- **DataProduct:** dataset lógico, owner, descripción, sensibilidad, finalidad, versión.
- **Asset:** archivo, tabla, evidencia, certificado, imagen, registro o documento.
- **FieldDefinition:** nombre, tipo, unidad, obligatoriedad, sensibilidad, salida permitida.
- **Policy:** permisos, prohibiciones, obligaciones, restricciones y enforcement point.
- **Agreement:** acuerdo legal/humano vinculado a políticas y versiones.
- **DataGrant:** autorización concreta: quién accede, a qué, por qué, hasta cuándo.
- **OutputRequest:** solicitud de informe/export/vista.
- **OutputApproval:** aprobación, rechazo, comentarios y condiciones.
- **AuditEvent:** evento trazable.
- **LineageEvent:** relación entre fuente, transformación y output.
- **RiskFinding:** gap técnico/legal/comercial.

6.2 Estados recomendados

- Room: draft → configured → active → output_review → closed → archived.
- Evidence: requested → submitted → under_review → approved → rejected → expired.
- Output: draft → review_requested → approved → exported → revoked.
- Agreement: draft → sent → accepted → superseded → expired.

7. API funcional objetivo

MVP puede ser UI-first, pero conviene diseñar contratos claros:

- `POST /rooms` crear sala.
- `GET /rooms/:id` ver sala según permisos.
- `POST /rooms/:id/participants` invitar organización/usuario.
- `POST /rooms/:id/data-products` registrar dataset.
- `POST /data-products/:id/assets` subir evidencia.
- `PATCH /assets/:id/classification` clasificar sensibilidad/salida.
- `POST /rooms/:id/policies` definir reglas.
- `POST /rooms/:id/agreements` generar acuerdo/condiciones.
- `POST /outputs` solicitar output.
- `POST /outputs/:id/review` revisar y comentar.
- `POST /outputs/:id/approve` aprobar.
- `POST /outputs/:id/export` exportar si pasa reglas.
- `GET /rooms/:id/audit` consultar audit log.
- `GET /outputs/:id/audit-pack` descargar paquete de auditoría.

8. Seguridad y privacidad como requisitos, no extras

8.1 Activos a proteger

- Secretos industriales: recetas, BOM, parámetros, consumos, scrap, capacidad, costes, proveedores.
- Datos PCF/sostenibilidad: factores, supuestos, volúmenes, energía, evidencias.
- Datos de calidad/trazabilidad: lotes, certificados, no conformidades, fotos, informes.

- Datos personales: usuarios, logs, operarios, turnos, matrículas, firmas, imágenes o correos.
- Metadatos sensibles: cambios, huecos de evidencia, retrasos y patrones de acceso.

8.2 Controles P0 para piloto real

- Separación por sala/organización.
- Deny-by-default.
- Roles mínimos y permisos explícitos.
- Accesos con caducidad.
- Revocación inmediata.
- Logs de acciones críticas.
- Clasificación de sensibilidad.
- Reglas de salida por campo/evidencia.
- Preview por rol antes de exportar.
- Bloqueo de export si falta owner, clasificación o aprobación.
- Retención/cierre definido.
- Gestión de secretos fuera del repo, frontend y logs.

8.3 Controles P1/V1

- SSO/OIDC/SAML.
- MFA para admins, approvers y externos.
- Watermark por usuario/export.
- Hash de exports.
- Antivirus/malware scanning de adjuntos.
- DLP básico.
- Alertas por descarga masiva, IP/país anómalo o múltiples fallos.
- KMS y cifrado por tenant/sala si procede.
- SIEM export.
- Pentest/revisión seguridad antes de producción enterprise.

8.4 Incidentes

- Registro de incidente con sala, datasets, usuarios, periodo, impacto y acciones.
- Suspensión de accesos afectados.
- Preservación de logs.
- Comunicación contractual según rol y obligación.
- Timeline de investigación.
- Postmortem y cambios de control.

9. Requisitos regulatorios traducidos a producto

9.1 Data Act

Features:

- Registrar data holder, user y third-party recipient.

- Workflow de solicitud, aprobación/rechazo y caducidad.
- Restricciones de uso: finalidad, no uso competitivo, no transferencia no autorizada, retención.
- Entrega machine-readable en fase posterior.
- Registro de secretos comerciales y medidas técnicas antes de compartir.
- Registro de suspensiones/rechazos y justificación.

Límite:

- No decir “Data Act compliant”; decir “preparación operativa y evidencias para revisión Data Act”.

9.2 Data Governance Act

Features:

- Separación de tenants.
- No reutilización de datos de clientes para fines propios salvo autorización y análisis legal.
- Transparencia de condiciones, destinatarios, subprocesadores y localización.
- Registro de rol: SaaS técnico, processor, data intermediary, marketplace o broker.

Límite:

- Evitar presentarse como “data intermediary DGA” sin análisis formal.

9.3 GDPR/RGPD

Features:

- Clasificador de datos personales/no personales/seudonimizados/mixtos.
- Base jurídica y roles: controller, processor, joint controllers, subprocessor.
- DPA Art. 28 si aplica.
- Retención configurable.
- Derechos de interesados si aplica.
- DPIA readiness si hay monitorización, geolocalización o datos de trabajadores.

Límite:

- “Industrial” no significa “no personal”. No prometer anonimización universal.

9.4 Secretos comerciales

Features:

- Clasificación: público, interno, confidencial, secreto comercial, export restricted, solo agregados.
- Flujo de handling de secretos.
- Clean room / consulta sin crudo como objetivo posterior.
- Watermark/fingerprint en exports.
- Cláusulas de no reverse engineering, no benchmark no autorizado y no uso competitivo.

Límite:

- La plataforma ayuda a demostrar medidas razonables, pero no crea protección legal por sí sola.

9.5 NIS2 / ciber

Features:

- Evidence pack de seguridad.
- Gestión de incidentes.
- Proveedores/subprocesadores y ubicación de datos.
- Backups y continuidad.
- Logs exportables.

Límite:

- NIS2 depende de país, sector y transposición. DataSafe Room no sustituye el programa de ciberseguridad del cliente.

9.6 ESPR / Digital Product Passport

Features:

- Modelo DPP-ready: producto, lote/serie, fabricante, materiales, componentes, certificados, lifecycle events.
- Identificadores: product ID, batch ID, serial ID, facility ID, supplier ID.
- Niveles de acceso: público, cliente, proveedor, autoridad, auditor, interno.
- Tracker de aplicabilidad por categoría/acto delegado.

Límite:

- No vender “DPP compliant” general. Vender preparación estructurada.

9.7 CSRD / ESRS / Scope 3 / PCF

Features:

- Workspace de evidencias PCF.
- Datos primarios vs estimados.
- Metodología declarada: ISO 14067, GHG Protocol Product Standard, PEF u otra elegida por cliente.
- Data quality scoring.
- Audit trail de contribuciones y versiones.
- Export de evidence pack para reporting/auditoría.

Límite:

- No es motor de reporting CSRD ni certificador PCF.

10. MVP y fases

10.1 Sprint de 7 días — diagnóstico + demo

Objetivo: demostrar el concepto y decidir si hay piloto pagado.

Incluye:

- 1 caso concreto.
- Dataset sintético o muestra aprobada.
- Mapa de participantes.
- Matriz dato → owner → sensibilidad → salida permitida.
- Mock/demo end-to-end: solicitud → aporte → revisión → reglas → aprobación → audit pack.
- Riesgos, gaps y supuestos.
- Propuesta de piloto 4–8 semanas.

No incluye:

- Datos productivos sin aprobación.
- Compliance legal.
- Certificación PCF.
- Integraciones ERP/MES/SCADA/PLC.
- Seguridad enterprise.
- Dataspace federado.

Criterio de éxito:

- Sponsor entiende el valor.
- Hay contraparte real o potencial.
- Hay datos accesibles sin abrir OT.
- Existe problema con coste visible.
- Se acepta discutir piloto pagado.

10.2 MVP operativo 4–8 semanas

Objetivo: una sala real acotada con 2–3 organizaciones/roles.

Incluye:

- Sala con finalidad, alcance, fechas y participantes.
- Autenticación y permisos por rol.
- Intake controlado de datos/evidencias.
- Versionado básico.
- Clasificación de sensibilidad.
- Reglas de salida.
- Preview por rol.
- Approval gate antes de export.
- Audit log funcional.
- Audit pack final.
- Retención/cierre definido.
- Pruebas negativas documentadas.

Criterio de éxito:

- Usuario externo con vista limitada puede completar tarea.
- Export con campo interno se bloquea.

- Audit pack reconstruye versión, evidencia, aprobador y salida.
- Se mide baseline contra Excel/email.
- Sponsor puede decidir go/no-go de escalado.

10.3 V1 producto robusto

- SSO/MFA enterprise.
- Watermarking y hash de exports.
- Scanning de adjuntos.
- Data quality scoring avanzado.
- API scoped tokens.
- Dashboards por caso.
- Audit log hardening.
- Integraciones cloud/storage aprobadas.
- Security evidence pack.

10.4 V2 dataspace federado

Solo si hay necesidad real:

- Eclipse Dataspace Components / DSP.
- Catálogo federado.
- Credenciales verificables.
- ODRL/OPA/Cedar avanzado.
- Compute-to-data real.
- OpenLineage/Marquez.
- SIEM/SOAR.
- WORM/Object Lock.
- Conectores ERP/PLM/MES/historians con threat model.

11. Backlog priorizado

P0 — demo/diagnóstico

- Landing/narrativa comercial clara.
- Demo sintética PCF.
- Matriz de datos mínimos.
- Roles y vistas simuladas.
- Mock de approval gate.
- Mock de audit pack.
- Checklist legal/security.
- Preguntas de discovery.

P1 — MVP operativo

- Rooms multi-organización.
- Invitaciones y roles.

- Intake de evidencias.
- Data products/datasets con campos y clasificación.
- Reglas de salida por campo/evidencia.
- Preview por rol.
- Approval workflow.
- Export/audit pack.
- Audit log funcional.
- Retention/closure workflow.
- Pruebas de permisos/export/versionado.

P2 — hardening y escalado

- SSO/MFA.
- Watermarking.
- Hash de exports.
- Malware scanning.
- Data quality scoring.
- API scoped tokens.
- Dashboards de completitud/gaps.
- Templates PCF/Data Act/calidad.
- Security evidence pack.

P3 — federación/interoperabilidad

- EDC/DSP.
- Catálogo federado.
- Verifiable credentials.
- Políticas ejecutables avanzadas.
- Compute-to-data.
- OpenLineage.
- Integraciones OT/IT bajo aprobación.

12. UX mínima

12.1 Pantallas del MVP

- Dashboard de salas.
- Crear sala.
- Participantes y roles.
- Matriz de datos solicitados.
- Subida/revisión de evidencias.
- Clasificación de sensibilidad.
- Vista por rol.
- Solicitud de output.
- Approval gate.
- Audit pack.
- Riesgos/gaps.

- Cierre/retención.

12.2 Journey PCF recomendado

1. Cliente crea sala “PCF Producto X — proveedor A”.
2. Define finalidad: responder solicitud PCF sin revelar proceso/costes.
3. Invita proveedor y auditor/reviewer.
4. Solicita campos mínimos: producto, material, factor emisión, evidencia, periodo, fuente.
5. Proveedor sube evidencia y marca campos sensibles.
6. Room owner revisa completitud y gaps.
7. Preview muestra qué verá cliente.
8. Approver aprueba salida.
9. Cliente descarga/consulta audit pack.
10. Sala se cierra con retención y próximos pasos.

13. Métricas

13.1 Producto

- % campos con owner.
- % campos con sensibilidad clasificada.
- % evidencias aprobadas.
- Tiempo de ciclo solicitud → output.
- Nº gaps abiertos/cerrados.
- Nº exports bloqueados por regla.
- Nº accesos externos correctos.

13.2 Negocio

- Tiempo actual por Excel/email vs sala.
- Nº iteraciones de corrección evitadas.
- Nº proveedores/participantes activos.
- Sponsor acepta siguiente fase.
- Piloto pagado o LOI.
- Reducción percibida de fricción/riesgo.

13.3 Riesgo

- Campos sensibles protegidos.
- Datos evitados/no solicitados.
- Exports con aprobación.
- Incidentes o accesos denegados.
- Gaps legales/security abiertos.

14. Paquetes comerciales internos

Hipótesis de validación. No publicar como tarifa cerrada sin ajustar alcance.

14.1 Diagnostic Use Case — 7 días

- Precio hipótesis: 3.000–6.000 €.
- Entrega: mapa de datos, demo sintética/mock, matriz de riesgos, business case y propuesta de piloto.
- Riesgo bajo; no producción.

14.2 Controlled Pilot — 4–8 semanas

- Precio hipótesis: 12.000–30.000 €.
- Entrega: sala operativa acotada, 2–3 participantes, evidencias, permisos, output approval y audit pack.
- Requiere NDA, DSA/DPA si aplica, owners e IT/security.

14.3 Operational Data Room — recurrente

- Retainer hipótesis: 1.500–5.000 €/mes + implementación.
- Entrega: operación recurrente, soporte, conectores aprobados, hardening, métricas y expansión de casos.

15. Discovery comercial

Preguntas clave:

- ¿Qué dato os pide hoy un cliente/proveedor/auditor y cómo lo respondéis?
- ¿Qué parte os da miedo compartir?
- ¿Qué dato sería suficiente si no compartimos el bruto?
- ¿Quién es dueño del dato?
- ¿Hay datos personales, secretos comerciales o datos de trabajadores?
- ¿Qué sistemas no se pueden tocar en un primer piloto?
- ¿Qué output necesita la otra parte realmente?
- ¿Cómo se aprueba hoy una evidencia antes de enviarla?
- ¿Cuánto tarda el proceso por email/Excel?
- ¿Qué pasaría si respondéis tarde o mal?

Go/no-go:

- Go si hay caso multiempresa real, coste visible, sponsor, datos exportables, owner y aceptación de piloto limitado.
- No-go si el cliente pide compliance cerrado, integración industrial inmediata, muchos casos a la vez o no hay contraparte.

16. Riesgos y bloqueos

16.1 Riesgos comerciales

- “Dataspace” suena abstracto o subvención.
- Sin contraparte real, la sala es un data room vacío.
- El comprador pide alcance enterprise con presupuesto de demo.
- PCF puede requerir metodología especializada.
- Legal/IT quedan fuera cuando deberían participar.

16.2 Riesgos técnicos

- Multiempresa sin segregación clara.
- Descargas habilitadas por defecto.
- Audit log editable.
- Evidencias sin owner/versión/fecha.
- Campos internos aparecen en export.
- Links reenviables/permanentes.
- Se afirma sandbox/egress control sin pruebas.
- No hay retención/cierre.

16.3 Riesgos legales/compliance

- Datos personales inadvertidos.
- Secretos comerciales mal clasificados.
- Transferencias internacionales.
- Roles GDPR/Data Act mal definidos.
- DGA si se opera como intermediario/marketplace.
- NIS2 por clientes críticos.
- DPP/CSRD mal interpretado como cumplimiento automático.

17. QA gate antes de enseñar a cliente

- Copy sin “seguro”, “completo”, “automático”, “certificado”, “cumplimiento garantizado”.
- Scope visible: 7 días diagnóstico/demo; 4–8 semanas piloto operativo acotado.
- No-promesas explícitas incluidas.
- Supuestos visibles: datos, owners, legal, IT, contraparte y sensibilidad.
- Criterios de éxito medibles.
- RACI mínimo definido.
- Riesgos y red flags incluidos.
- Demo etiqueta claramente datos sintéticos/prototipo.
- Si hay datos reales: NDA/DSA/DPA/security review según aplique.

18. Qué NO construir al principio

- Marketplace abierto de datos.
- Dataspace federado completo.
- Gaia-X/IDSA/EDC compliance.

- Blockchain.
- Federated learning.
- Confidential computing.
- Integración PLC/SCADA/MES/ERP directa.
- Cálculo PCF certificado.
- Motor legal automático.
- BI/notebooks con internet o descarga libre.
- Export crudo por defecto.

19. Stack técnico recomendado

MVP pragmático:

- React/Vite o Next.js para UI.
- Backend API con FastAPI/NestJS/Spring Boot según velocidad del equipo.
- PostgreSQL para metadatos, políticas, auditoría funcional.
- S3/MinIO para evidencias.
- Keycloak/OIDC para identidad si se avanza desde demo.
- Object storage privado.
- Workers para generación de audit pack.
- Plantillas PDF/ZIP/CSV controladas.

V1:

- OIDC/SAML enterprise.
- KMS.
- Malware scanning.
- SIEM export.
- OpenLineage si hay transformaciones.
- API scoped tokens.
- Watermarking.

V2:

- Eclipse Dataspace Components si hay federación real.
- DSP/EDC connectors.
- DCAT/ODRL formales.
- Verifiable credentials.

20. Fuentes oficiales y técnicas base

- EU Data Act — Regulation (EU) 2023/2854: <https://eur-lex.europa.eu/eli/reg/2023/2854/oj>
- European Commission — Data Act: <https://digital-strategy.ec.europa.eu/en/policies/data-act>
- Data Governance Act — Regulation (EU) 2022/868: <https://eur-lex.europa.eu/eli/reg/2022/868/oj>
- European Commission — Data Governance Act: <https://digital-strategy.ec.europa.eu/en/policies/data-governance-act>
- GDPR — Regulation (EU) 2016/679: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

- Trade Secrets Directive — Directive (EU) 2016/943: <https://eur-lex.europa.eu/eli/dir/2016/943/oj>
- NIS2 — Directive (EU) 2022/2555: <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
- ESPR / Digital Product Passport — Regulation (EU) 2024/1781: <https://eur-lex.europa.eu/eli/reg/2024/1781/oj>
- CSRD — Directive (EU) 2022/2464: <https://eur-lex.europa.eu/eli/dir/2022/2464/oj>
- ESRS — Delegated Regulation (EU) 2023/2772: https://eur-lex.europa.eu/eli/reg_del/2023/2772/oj
- Common European Data Spaces: <https://digital-strategy.ec.europa.eu/en/policies/data-spaces>
- Data Spaces Support Centre Blueprint: <https://dssc.eu/space/BVE/357073028/DSSC+Blueprint>
- International Data Spaces Association: <https://internationaldataspaces.org/>
- Eclipse Dataspace Components: <https://github.com/eclipse-edc/Connector>
- W3C DCAT 3: <https://www.w3.org/TR/vocab-dcat-3/>
- W3C ODRL: <https://www.w3.org/TR/odrl-model/>
- Catena-X Product Carbon Footprint: <https://catena-x.net/en/offers/use-cases/product-carbon-footprint>
- WBCSD PACT: <https://www.carbon-transparency.com/>
- ENISA good practices for IoT/smart manufacturing: <https://www.enisa.europa.eu/publications/good-practices-for-security-of-iot>

21. Entregables creados por perfiles especializados

- **Portia / Legal-Regulatory:** requisitos y límites regulatorios EU traducidos a features.
- **Mimir / Data Architecture:** arquitectura funcional/técnica y modelo de objetos/API.
- **Valentine / Product Strategy:** propuesta de valor, journeys, backlog, paquetes y métricas.
- **Aegis / Security-OT:** amenazas, controles, requisitos MVP/v1 y checklists de seguridad.
- **Columbo / QA Commercial Gate:** claims peligrosos, lenguaje seguro, red flags y criterios de aprobación.

22. Próxima acción recomendada

Crear una **demo sintética PCF cliente-proveedor** con el flujo mínimo:

1. Crear sala.
2. Invitar proveedor y cliente.
3. Solicitar datos PCF mínimos.
4. Subir evidencia sintética.
5. Clasificar sensibilidad.
6. Preview por rol.
7. Aprobar output.
8. Generar audit pack.

Esto valida si DataSafe Room es comprensible y vendible antes de invertir en federación, conectores o compliance avanzado.